

القسم ١: تقرير الأخطاء والمشاكل

ملخص تنفيذي سريع

- النظام الحالي هجين بين بيانات حقيقية وبيانات تجريبية: صفحة dashboard تعرض جزءًا حقيقيًا من قياسات النظام، بينما صفحات analytics و threat_management تحتوي مؤشرات ثابتة.
- طبقة "الذكاء الاصطناعي" الحالية ليست ML فعليًا؛ هي محرك قواعد/عتبات في perception, prediction, decision_engine.
- لا توجد قاعدة بيانات تشغيلية أو تخزين دائم للحالة؛ أغلب الحالة أمنياً موجودة في الذاكرة فقط.

تصنيف المشاكل

حرجة

- واجهة API إدارية بدون مصادقة/تفويض

- المكان (web_dashboard/app.py): نقاط مثل /api/block-ip, /api/analyze-entity, /api/network-interfaces, /api/processes
- السبب: لا توجد طبقة AuthN/AuthZ أو قيود صلاحيات قبل تنفيذ عمليات حساسة.
- التأثير: أي عميل قادر على الوصول للشبكة يستطيع استدعاء وظائف حساسة، تحليل كيانات، واستكشاف معلومات النظام.

- مفتاح جلسات ثابت ومكشوف

- المكان: web_dashboard/app.py
- السبب: SECRET_KEY: مكتوب نصياً داخل الكود.
- التأثير: مخاطر تزوير/اختراق جلسات وتوقعات الكوكيز إذا عُرف المفتاح.

- فتح Socket.IO لجميع الأصول + ربط الخدمة على 0.0.0.0

- المكان: web_dashboard/app.py, web_dashboard/run_web_dashboard.py
- السبب: cors_allowed_origins="*": مع تشغيل عام على كل الواجهات الشبكية.
- التأثير: توسع سطح الهجوم وإمكانية استهلاك/إساءة قنوات التحديث اللحظي من مصادر غير موثوقة.

- تضليل تشغيلي: إجراء "Block IP" لا يطبق حجباً فعلياً

- المكان: web_dashboard/app.py + response/engine.py
- السبب: الإجراء يسجل حدثاً فقط، ولا يوجد تكامل فعلي مع Firewall/ACL.
- التأثير: فريق التشغيل قد يعتقد أن الدفاع الوقائي نُفذ بينما الخطر ما زال قائماً.

متوسطة

- لوحة التحكم لا تعكس النشاط الحقيقي بشكل كامل

- المكان: web_dashboard/templates/analytics.html, web_dashboard/templates/threat_management.html
- السبب: استخدام قيم ثابتة (12, 2, 47) وقيم عشوائية (Math.random) ورسوم بيانية تجريبية.

- التأثير: قرارات SOC مبنية على بيانات غير موثوقة. (False Confidence)
 - تتبّع البيانات بين الواجهة والخلفية غير متسق
 - المكان: dashboard.html مقابل analytics.html وthreat_management.html
 - السبب: بعض المؤشرات موصولة بـ API فعلي، وأخرى مشتقة/صورية دون مصدر حقيقي.
 - التأثير: تضارب بين الصفحات حول "حالة الأمن" نفسها.
 - انعدام التخزين الدائم للحالة الأمنية
 - المكان: trust_system/trust_manager.py, response/engine.py, web_dashboard/app.py
 - السبب: الاعتماد على هياكل ذاكرة (dict/list/deque) فقط.
 - التأثير: فقدان السجل عند إعادة التشغيل، صعوبة التدقيق الجنائي، وعدم ملاءمة التوسع متعدد العمليات.
 - خطر Race Conditions في الحالة المشتركة
 - المكان: نفس الملفات أعلاه مع مهام بث Socket.IO الخلفية.
 - السبب: تحديث متزامن لهياكل مشتركة دون حماية تزامن.
 - التأثير: حالات متضاربة في العدادات/الإنذارات/الاستجابات تحت الضغط.
 - قياسات الأداء تحتوي سلوكًا حاجبًا
 - المكان: web_dashboard/app.py (psutil.cpu_percent(interval=1))
 - السبب: استدعاء blocking داخل مسارات API والبث.
 - التأثير: زيادة زمن الاستجابة وإمكانية اختناق الخدمة مع زيادة الطلبات.
 - منطق "Active Responses" قد يعطي صورة ناقصة
 - المكان: response/engine.py + dashboard.html, threat_management.html
 - السبب: الإجراء يُنقل سريعًا إلى COMPLETED بينما العرض يعتمد على حالات PENDING/EXECUTING.
 - التأثير: ظهور "active responses" رغم وجود إجراءات أمنية تم تنفيذها.
 - مشكلة اعتماديات/تشغيل
 - المكان: web_dashboard/run_web_dashboard.py
 - السبب: pip install -r requirements.txt يعتمد على current working directory لا مسار الملف.
 - التأثير: فشل تشغيل تلقائي عند التنفيذ من مجلد مختلف.
- بسيطة
- جودة معمارية منخفضة بسبب تعدد لوحات متداخلة

- المكان : dashboard.py, dashboard_simple.py, عدة نسخ : dashboard/, server_control_center*.py, interactive_dashboard.py
- السبب: تكرار وظائف بواجهات متعددة متباعدة.
- التأثير: ارتفاع كلفة الصيانة وتكرار العيوب.
- وثائق/ادعاءات تتجاوز التطبيق الفعلي
- المكان : README.md, PROJECT_STATUS_REPORT.md, PROJECT_SUMMARY.md
- السبب: وصف "ذكاء تنبؤي متقدم/جاهزية" بينما التنفيذ Rule-based تجريبي.
- التأثير: فجوة توقعات بين الإدارة/العمليات والواقع التقني.
- اختبارات محدودة النطاق
- المكان : tests/test_perception_behavior.py, tests/test_prediction_attack.py
- السبب: تغطية تركز على happy path دون اختبارات ضغط/تزامن/تكامل API شامل.
- التأثير: مخاطر انحدار وظيفي غير مكتشف في الإنتاج.

تحقق الربط) Frontend → API → Backend → Data Source النتيجة النهائية)

- dashboard: غالبية مؤشرات النظام (CPU/Memory/Disk/Connections) ديناميكية من psutil عبر /api/system-metrics.
- analytics: يحتوي مؤشرات كثيرة غير حقيقية (عشوائية/ثابتة/مشتقة غير موثقة كمؤشرات أمنية فعلية).
- threat_management: يحتوي عناصر تشغيلية كبيرة ثابتة أو تجريبية (counts/lists/timeline/table).

القسم ٢: خطة تطوير المشروع

تحسينات معمارية (Architecture)

- فصل واضح بين طبقات ingestion، detection، decision، response، audit.
- إدخال مخزن حالة دائم (أحداث، تنبيهات، استجابات، درجات ثقة) لدعم الاستمرارية والتدقيق.
- تحويل العمليات الثقيلة/الحاجة إلى مسارات غير متزامنة (workers/queues) بدل حصرها في مسارات الطلب المباشر.
- إزالة الازدواجية بين لوحات dashboard/وتوحيد واجهة تشغيل واحدة موثوقة.

تحسين ربط الواجهة مع الخلفية

- تعريف قاموس مؤشرات موحد (Metric Contract): اسم المؤشر، مصدره، زمن التحديث، دقته.
- منع عرض أي KPI دون مصدر API موثق؛ فصل "Demo" عن "Production Data" بصرياً ووظيفياً.
- توحيد مسارات البيانات بين الصفحات الثلاث بحيث لا تتناقض الأرقام لنفس المفهوم.
- إضافة مؤشرات جودة بيانات (data freshness, source status, error state) بدل تعويضات صامتة بقيم صفرية.

تصميم طبقة التنبؤ بالذكاء الاصطناعي

- الأهداف: كشف الشذوذ اللحظي، توقع مرحلة هجوم قادمة، تقليل الإنذارات الكاذبة، دعم دفاع استباقي.
- الخوارزميات المقترحة:
 - كشف شذوذ غير مراقب: Isolation Forest / One-Class SVM / Autoencoder
 - نمذجة سلاسل زمنية LSTM: أو Temporal CNN أو Transformer خفيف حسب حجم البيانات.
 - تصنيف هجومي مراقب عند توفر: XGBoost/LightGBM (Labels)
- متطلبات البيانات:
 - Telemetry زمني على مستوى host/process/network/auth
 - Labels للأحداث المؤكدة (incident outcomes)
 - بيانات سياقية: نوع الأصل، الحساسية، نافذة زمنية، baseline تاريخي.
- Feature Engineering مقترح:
 - معدلات متحركة (rolling windows) ، تغيرات مشتقة (delta/acceleration)
 - نسب فشل المصادقة، entropy لمنافذ/وجهات الشبكة، burst features.
 - ميزات سلوكية لكل كيان مقارنة بخطه الأساسي (entity baseline deviation)
- التكامل مع النظام الحالي:
 - إبقاء pipeline الحالي ك-fallback rule-engine
 - إضافة model_inference بعد perception وقبل decision_engine
 - دمج score القواعد + النموذج في policy موحدة قابلة للمعايرة.
- استراتيجية النشر:
 - مرحلة Shadow Mode (تنبؤ بلا تنفيذ) مع قياس دقة.
 - ثم Canary على نسبة محددة من الكيانات.
 - ثم تعميم تدريجي مع مراقبة drift وإعادة معايرة دورية.

ترتيب الأولويات

- P0: الأمان التشغيلي الفوري. (Auth, Secret, Exposure, Real blocking semantics)
- P1: مصداقية البيانات في الواجهة (إلغاء/فصل mock data)
- P2: متانة النظام. (Persistence, concurrency safety, observability)
- P3: AI الحقيقي. (pipeline + models + evaluation + phased rollout)